Report esercizio pratico

Lorenzo Sanna

24/04/2026

Regola firewall su pfSense per bloccare l'accesso alla DVWA di Metasploitable dalla macchina Kali Linux

Consegna:

Creare una regola firewall che blocchi l'accesso alla DVWA della MV Metasploitable da parte della MV Kali Linux e ne impedisca lo scan della porta.

Introduzione

La consegna chiede di configurare pfSense in modo che Kali Linux non possa più accedere alla DVWA ospitata su Metasploitable e, di conseguenza, non sia in grado di scansionarne la porta relativa al servizio web.

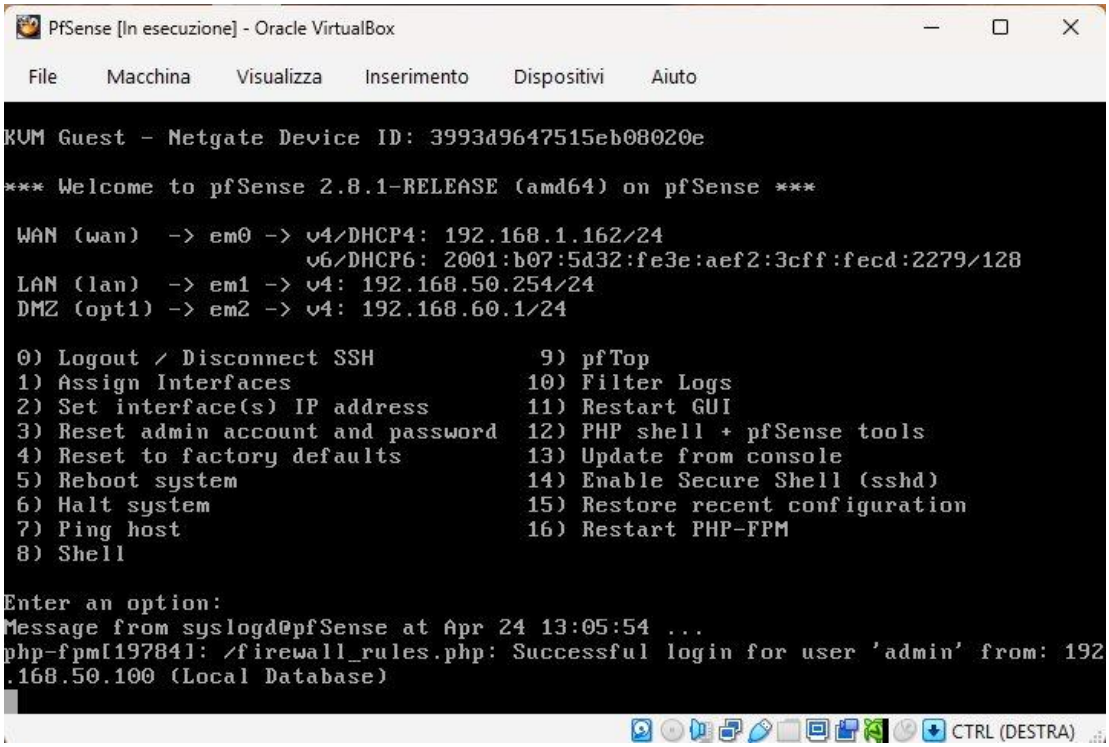
Per realizzarla ho impostato l'esercizio in modo che Kali e Metasploitable si trovino su due reti IP distinte, separate da pfSense che fa da router e da firewall. Questa scelta è vincolante, se le due VM fossero sulla stessa LAN, pfSense non vedrebbe proprio passare i pacchetti e non potrebbe filtrarli.

Topologia e indirizzamento

Ho usato tre VM su VirtualBox: Kali Linux come attaccante, Metasploitable2 come target, e pfSense come firewall centrale. pfSense è dotato di tre interfacce di rete, organizzate così:

Dispositivo	Interfaccia pfSense	Rete / CIDR	IP
pfSense (verso Internet)	WAN — em0 (bridge)	rete WiFi fisica	192.168.1.162 (DHCP)
pfSense (lato Kali)	LAN — em1 (Rete_Kali)	192.168.50.0/24	192.168.50.254
pfSense (lato Meta)	DMZ — em2 (Rete_Meta)	192.168.60.0/24	192.168.60.1
Kali Linux	—	192.168.50.0/24	192.168.50.100
Metasploitable2	—	192.168.60.0/24	192.168.60.100

Le due sottoreti private sono state scelte in modo da non sovrapporsi alla rete WiFi fisica a cui pfSense si collega tramite WAN. La configurazione finale si vede nella schermata della console:



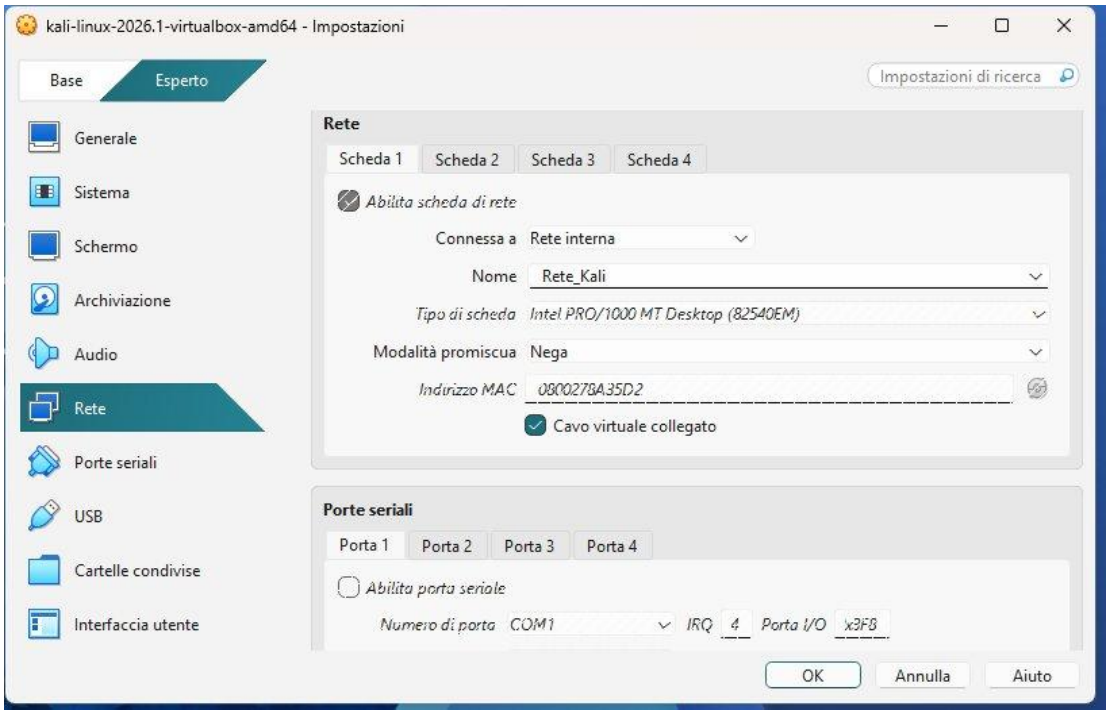
Screenshot 1 — Console di pfSense: WAN 192.168.1.162/24 in DHCP, LAN 192.168.50.254/24, DMZ 192.168.60.1/24.

Configurazione delle VM su VirtualBox

In VirtualBox ho creato due reti interne distinte, Rete_Kali e Rete_Meta, e ho collegato le schede di rete delle tre VM in modo che l'unico percorso tra Kali e Metasploitable passi da pfSense.

Kali Linux

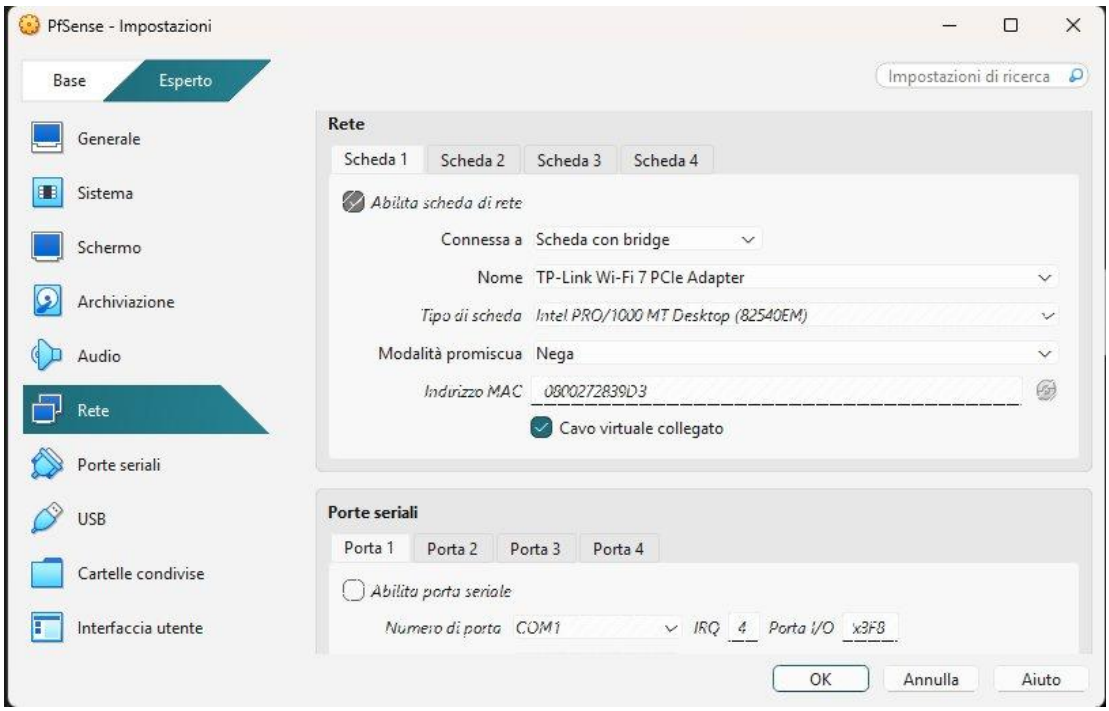
Una sola scheda, collegata a Rete_Kali.



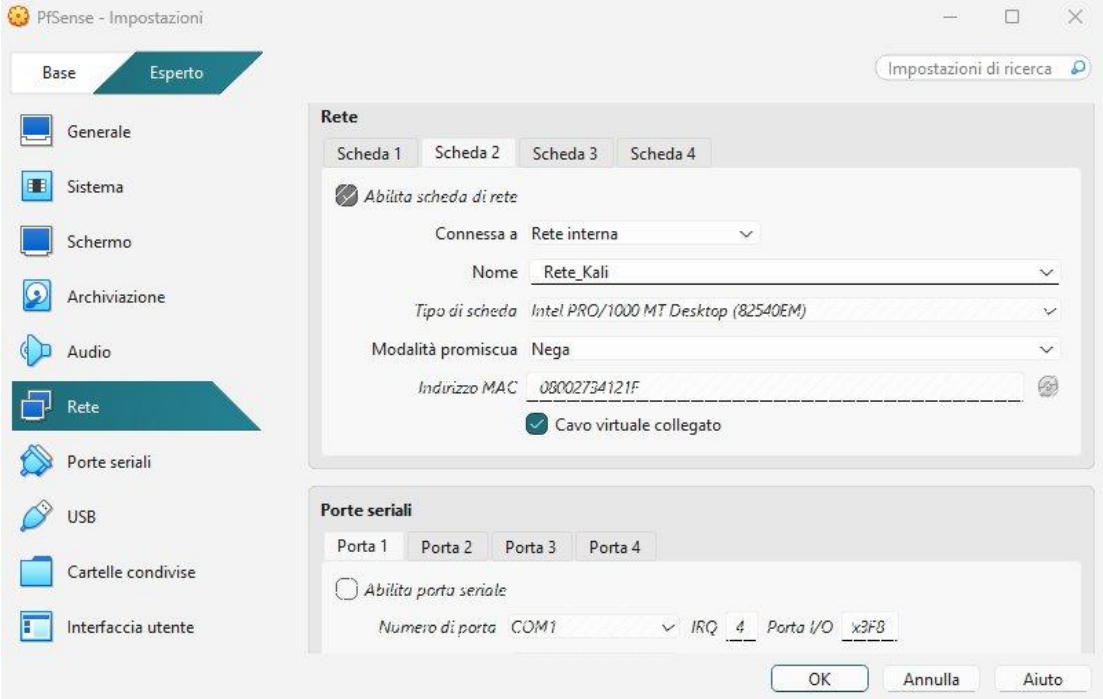
Screenshot 2 — Scheda 1 di Kali sulla rete interna Rete_Kali.

pfSense

Tre schede: la prima in bridge sull'adattatore WiFi fisico (TP-Link) per la WAN, la seconda sulla rete interna Rete_Kali per la LAN, la terza (aggiunta per questo esercizio) sulla rete interna Rete_Meta per la futura OPT1/DMZ.



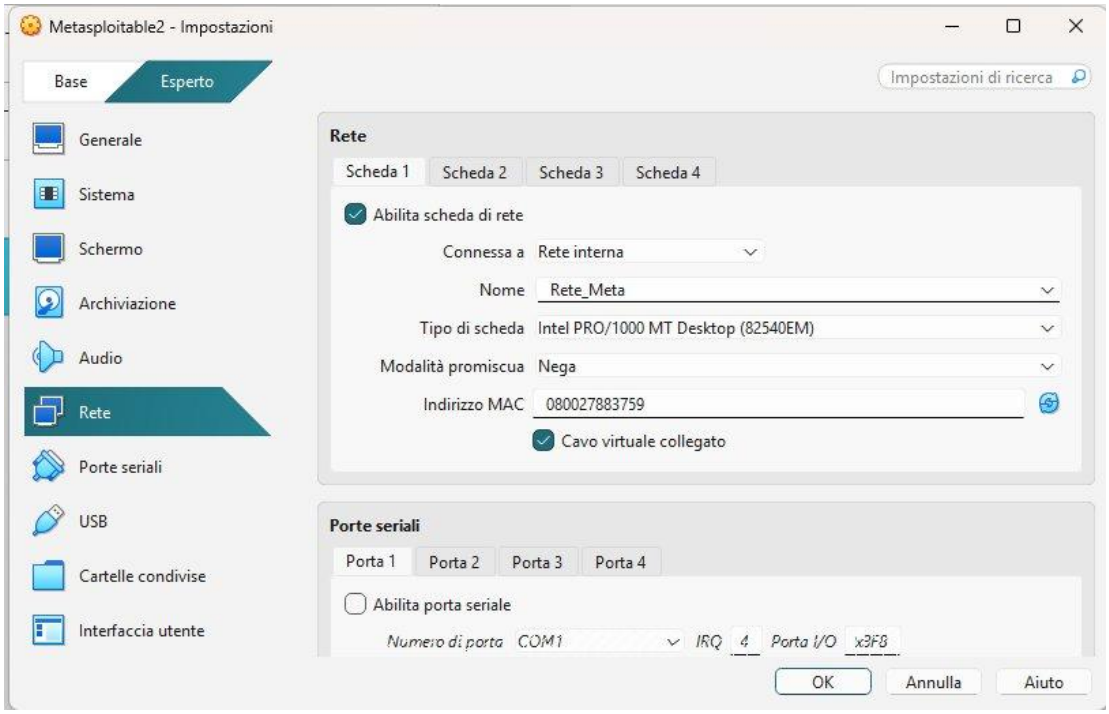
Screenshot 3 — pfSense, Scheda 1: bridge sulla WiFi TP-Link (WAN).



Screenshot 4 — pfSense, Scheda 2: rete interna Rete_Kali (LAN).

Metasploitable2

Una sola scheda, collegata a Rete_Meta, la stessa rete a cui è collegata la Scheda 3 di pfSense.



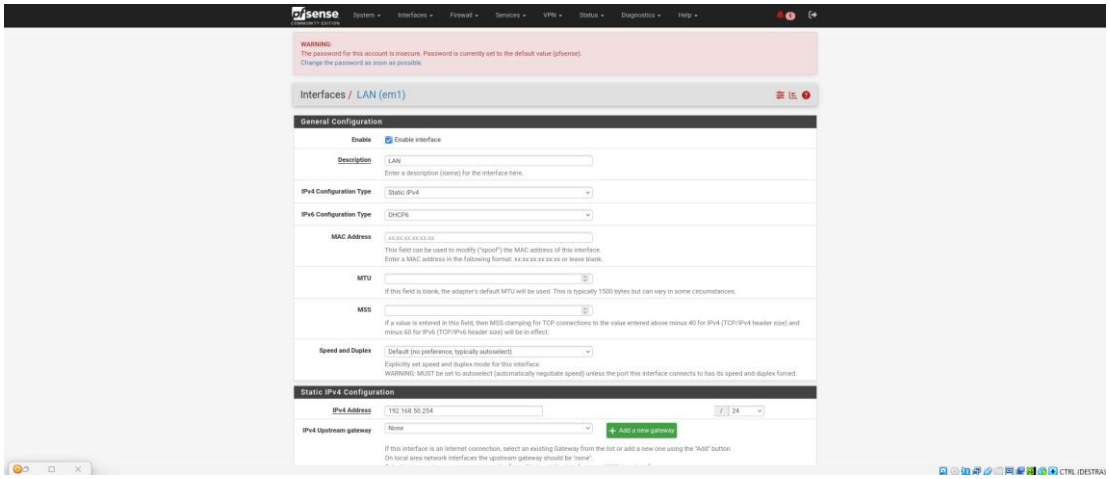
Screenshot 5 — Scheda 1 di Metasploitable sulla rete interna Rete_Meta.

Configurazione di pfSense

Con le tre schede collegate ai segmenti giusti, ho acceso pfSense e ho proceduto alla configurazione logica. La Web GUI è raggiungibile da Kali all'indirizzo https://192.168.50.254 (credenziali di default admin / pfsense).

Interfaccia LAN

La LAN era già presente, con IP statico 192.168.50.254/24 e nessun gateway upstream (il default gateway di pfSense è sulla WAN, non sulla LAN).



Screenshot 6 — Interfaccia LAN configurata con IP statico 192.168.50.254/24.

Aggiunta dell'interfaccia OPT1 (DMZ)

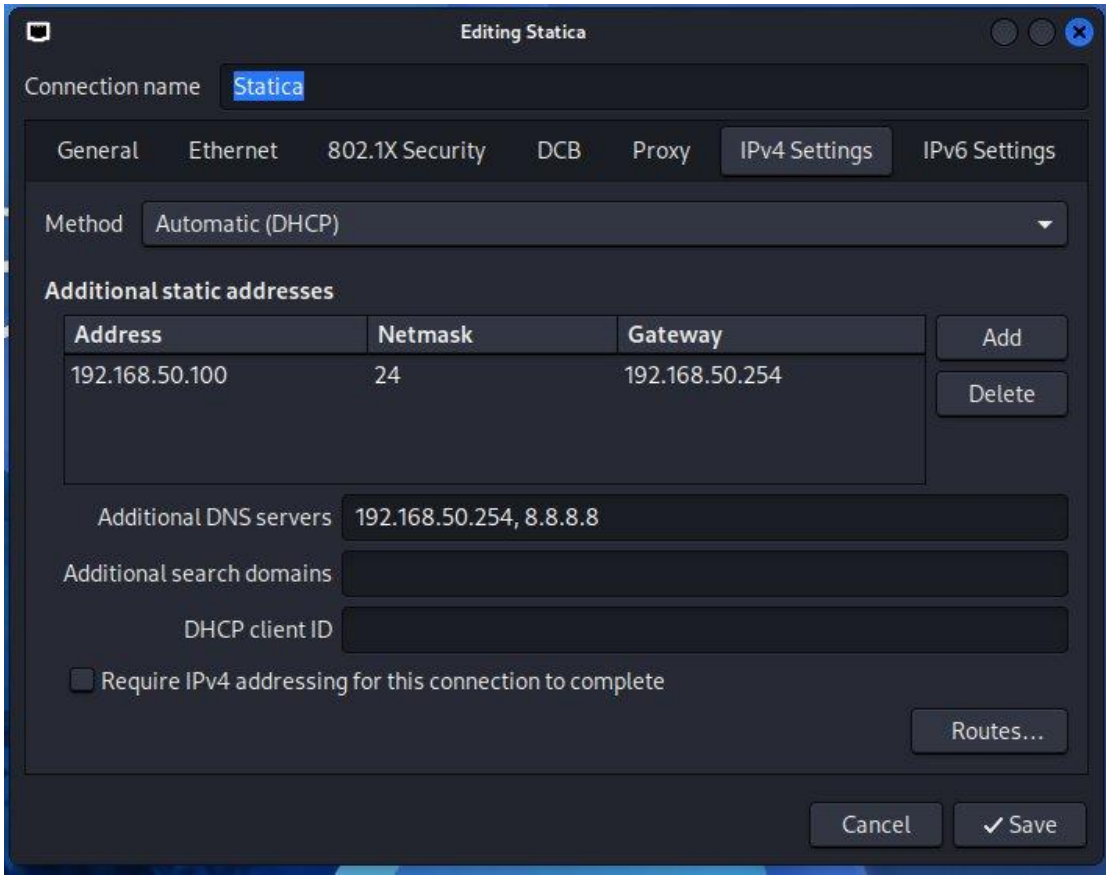
Questa è la parte nuova dell'esercizio. Dalla console di pfSense ho scelto l'opzione 1) Assign Interfaces e ho assegnato em2 come Optional 1. Successivamente, dalla Web GUI in Interfaces > OPT1, ho:

- Spuntato Enable interface.
- Rinominata l'interfaccia come DMZ nel campo Description.
- Impostato IPv4 Configuration Type: Static IPv4, con IP 192.168.60.1/24 e Upstream gateway: None.
- Disattivato le opzioni "Block private networks" e "Block bogon networks": la prima in particolare è fondamentale, perché altrimenti pfSense scarterebbe 192.168.60.0/24 considerandolo traffico privato non autorizzato.

Configurazione di rete sui client

Kali

Ho creato una connessione statica tramite NetworkManager con indirizzo 192.168.50.100/24, gateway 192.168.50.254 (ossia pfSense), e DNS 192.168.50.254 e 8.8.8.8.



Screenshot 7 — Connessione "Statica" di NetworkManager su Kali.

Metasploitable

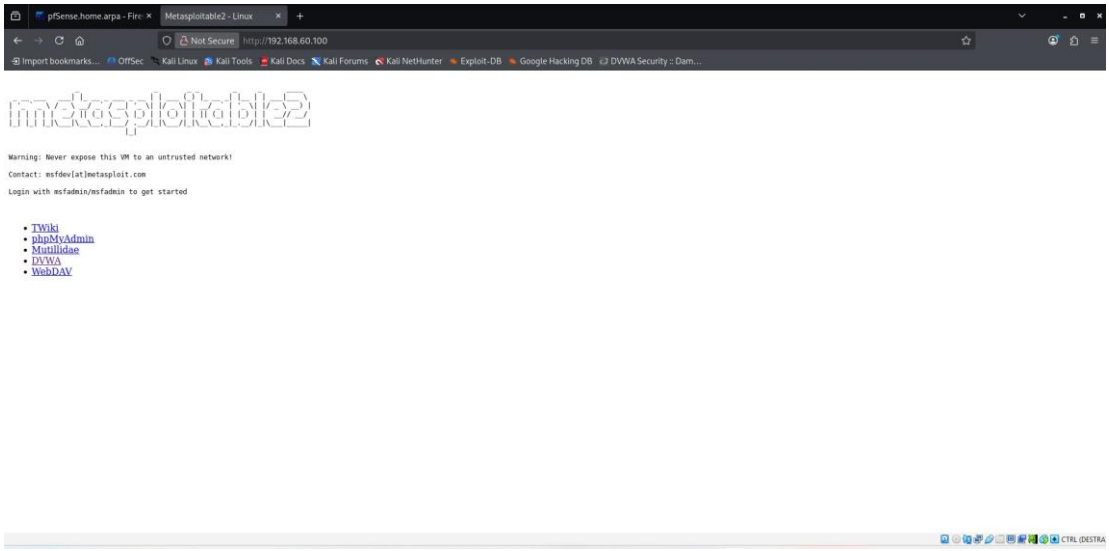
Dalla shell di Metasploitable (login msfadmin / msfadmin) ho impostato IP e gateway con:

```
sudo ifconfig eth0 192.168.60.100 netmask 255.255.255.0 up
sudo route add default gw 192.168.60.1
```

Verifica della connettività prima della regola

Accesso alla home di Metasploitable

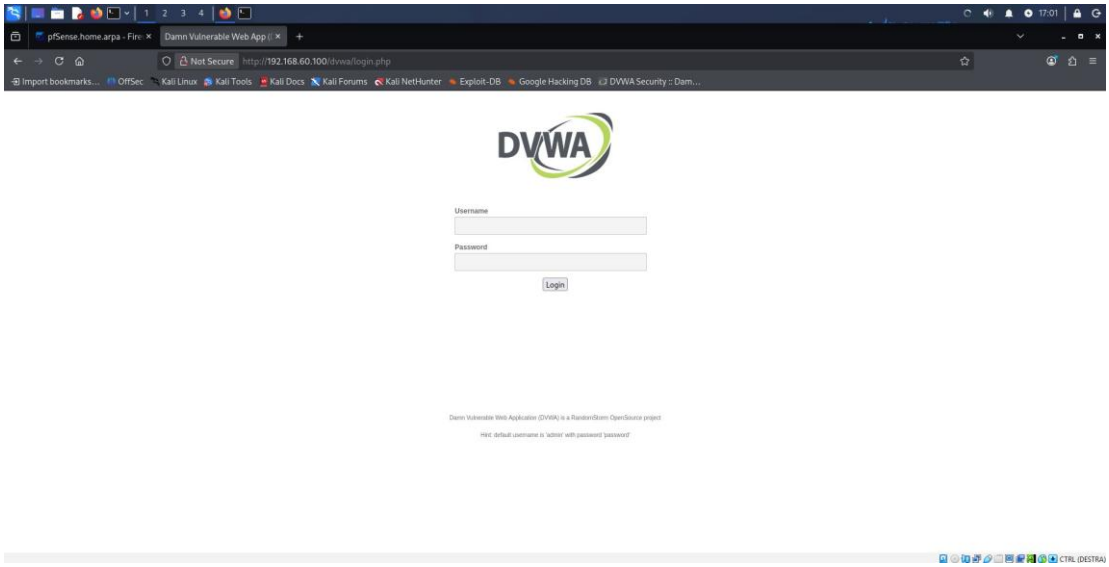
Da Firefox su Kali, l'indirizzo http://192.168.60.100 risponde con la classica pagina di benvenuto di Metasploitable2 e l'elenco delle applicazioni vulnerabili installate (TWiki, phpMyAdmin, Mutillidae, DVWA, WebDAV). Significa che il routing tra LAN e DMZ funziona correttamente.



Screenshot 8 — Home di Metasploitable2 accessibile dal browser di Kali.

Accesso alla DVWA

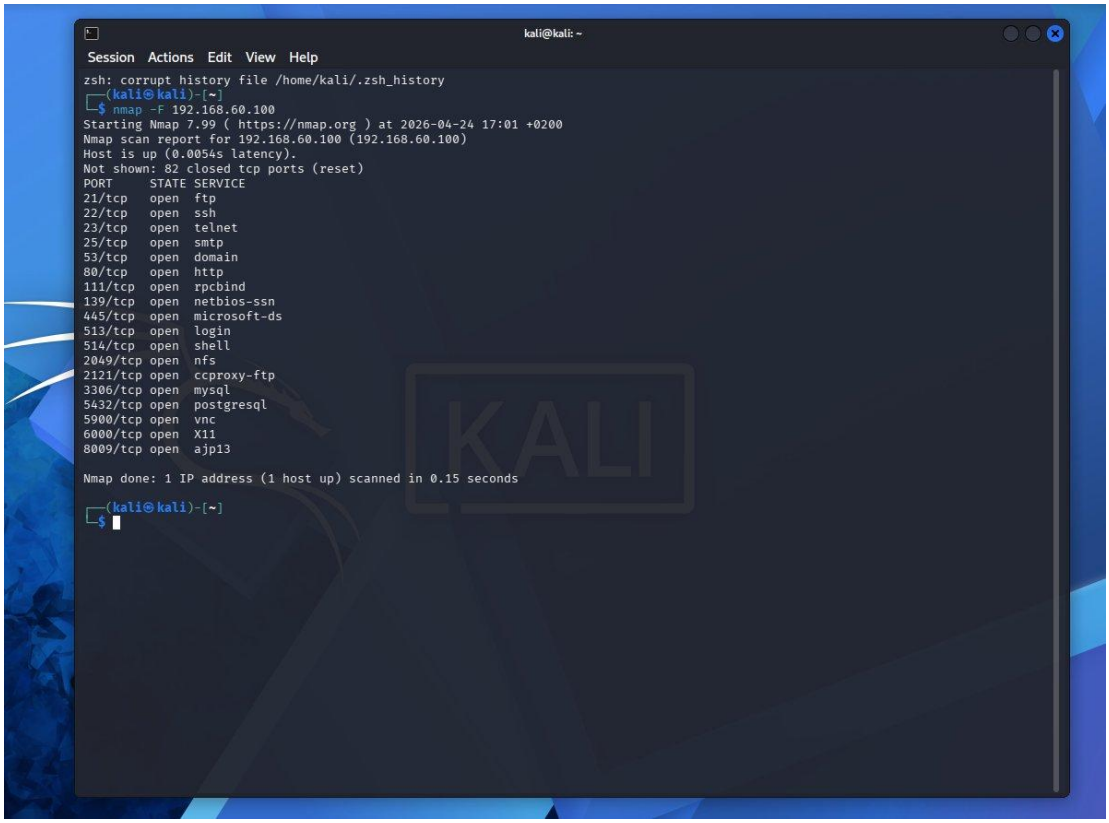
Cliccando sul link DVWA si apre la pagina di login dell'applicazione vulnerabile, che è proprio il servizio che dovrò rendere irraggiungibile.



Screenshot 9 — DVWA raggiungibile all'URL http://192.168.60.100/dvwa/login.php.

Scan delle porte con nmap

Il comando nmap -F esegue uno scan veloce sulle 100 porte più comuni. Prima della regola, la porta 80/http risulta open insieme a una lunga lista di altri servizi (ftp, ssh, telnet, smtp, mysql, vnc, ecc.).



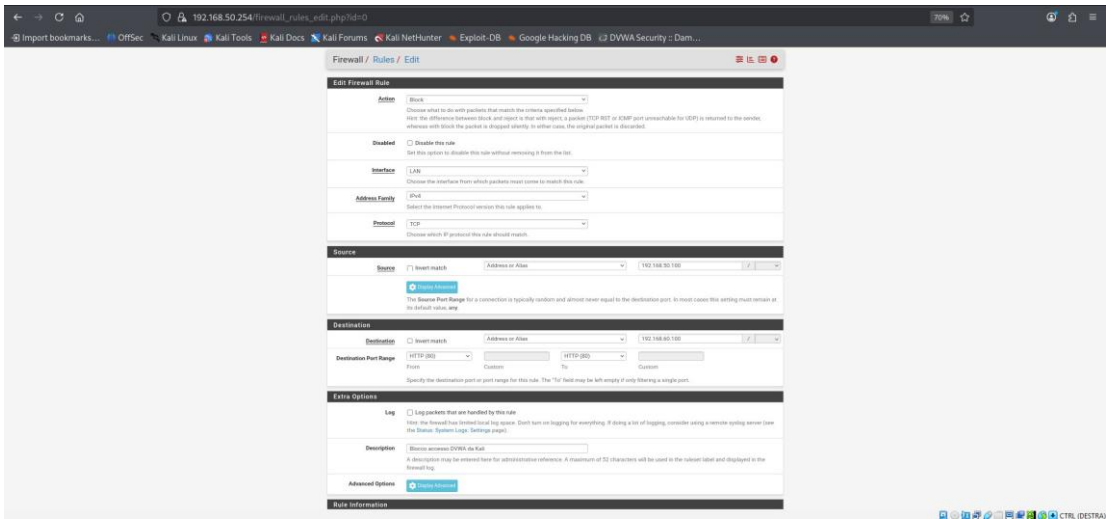
Screenshot 10 — nmap -F prima della regola: porta 80 in stato open.

Creazione della regola firewall

Per la regola sono andato in Firewall > Rules, tab LAN. In pfSense le regole si applicano sull'interfaccia di ingresso del pacchetto, e i pacchetti di Kali entrano dalla LAN.

Parametri

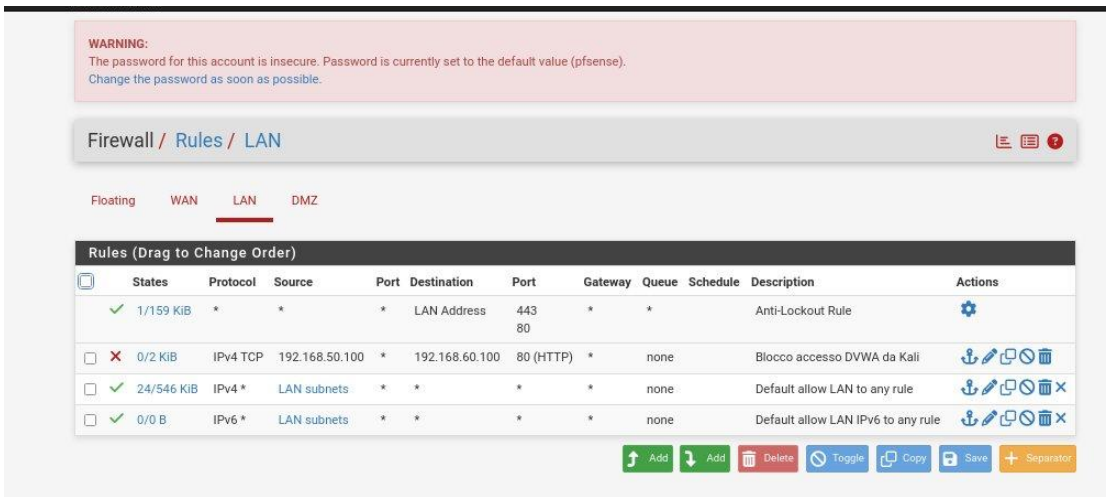
Campo	Valore
Action	Block
Interface	LAN
Address Family	IPv4
Protocol	TCP
Source	Address or Alias — 192.168.50.100 (Kali)
Destination	Address or Alias — 192.168.60.100 (Metasploitable)
Destination Port Range	HTTP (80) → HTTP (80)
Description	Blocco accesso DVWA da Kali



Screenshot 11 — Form di creazione della regola firewall con tutti i parametri compilati.

La regola attiva

Dopo Save e Apply Changes, la lista in Firewall > Rules > LAN mostra la nuova regola (icona X rossa) subito sopra la regola di default:



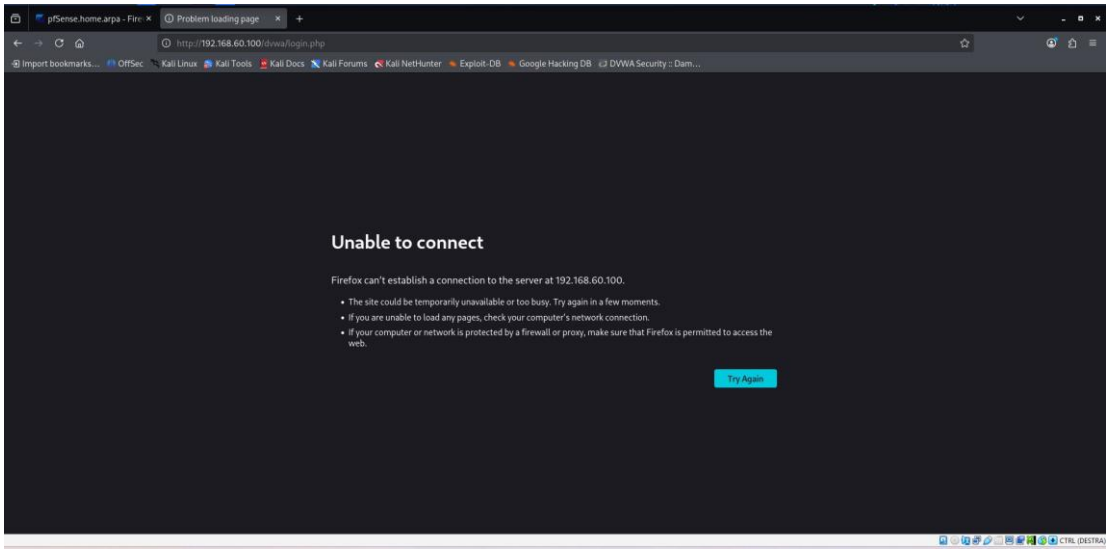
Screenshot 12 — La regola di blocco in cima alla lista dell'interfaccia LAN.

Verifica dell'efficacia della regola

Ho rieseguito i test per confrontare il comportamento prima e dopo.

Accesso via browser

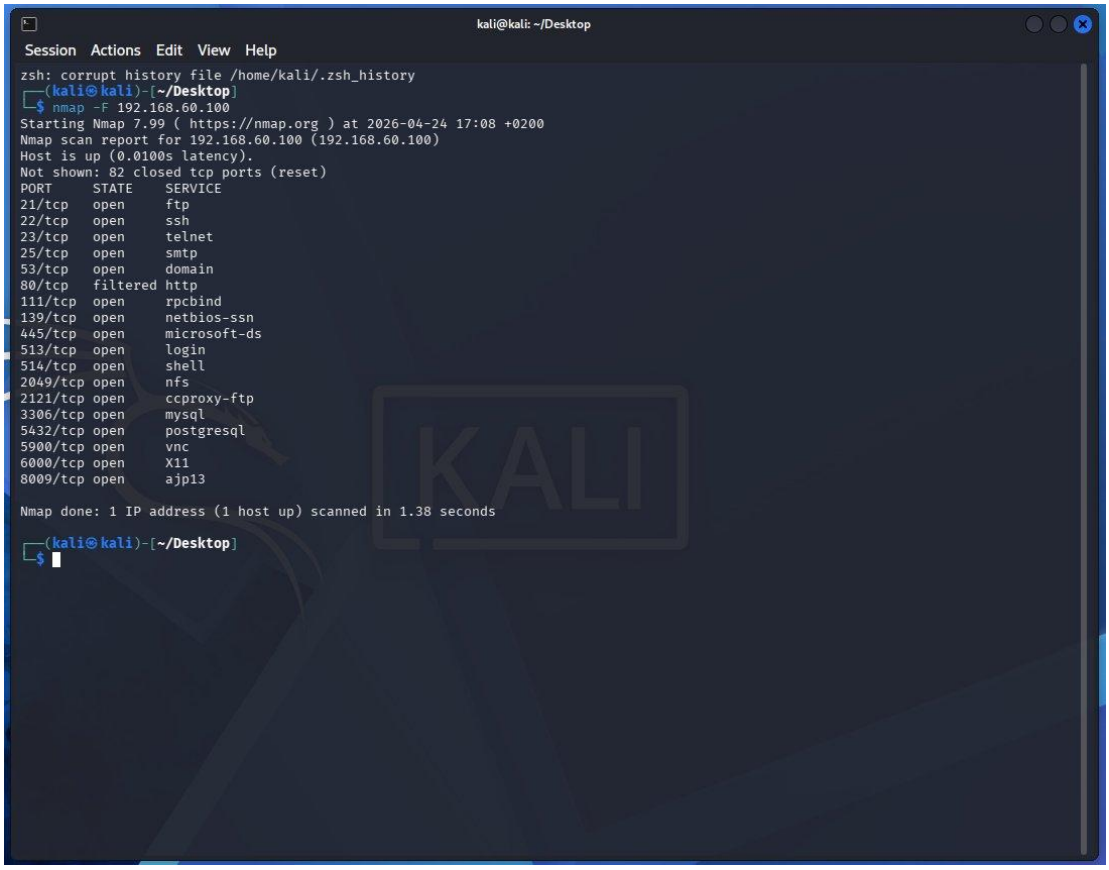
Ricaricando http://192.168.60.100/dvwa/login.php il browser mostra l'errore "Unable to connect - Firefox can't establish a connection to the server at 192.168.60.100". La DVWA non è più raggiungibile da Kali.



Screenshot 13 — Tentativo di accesso a DVWA dopo l'applicazione della regola.

nmap dopo il blocco

Rilanciando nmap -F 192.168.60.100 la porta 80 cambia stato da open a filtered, mentre tutte le altre restano open. Il risultato conferma due cose: la regola funziona (la 80 non è più visibile), e il blocco è mirato (gli altri servizi non sono stati toccati).



Screenshot 14 — nmap -F dopo la regola: porta 80 in stato filtered, tutte le altre ancora open.

Lo stato filtered nasce proprio dal comportamento dell'azione Block: nmap invia un pacchetto SYN, non riceve alcuna risposta (né SYN/ACK) entro il timeout, e non può dedurre lo stato reale della porta.

Conclusioni

L'obiettivo della consegna è stato raggiunto: Kali non può più accedere alla DVWA, né in browser né tramite scan della porta 80. I passaggi chiave sono stati tre:

- Aggiungere a pfSense una terza interfaccia (OPT1/DMZ, 192.168.60.1/24) e spostare Metasploitable su quella rete, così da forzare il traffico ad attraversare il firewall.
- Scrivere una regola Block mirata su TCP/80, posizionata in cima alle regole LAN in modo che venga valutata prima della regola di default.
- Verificare il risultato con browser e nmap, ottenendo rispettivamente "Unable to connect" e lo stato filtered sulla porta bloccata.

L’esercizio mostra come pfSense permetta un filtraggio granulare per host, protocollo e porta, utile in contesti reali per isolare servizi sensibili senza dover isolare completamente un intero sistema.